INTERAFAS-LAB

Pulso Metropolitano

Sistema de Gestión de Seguridad de la Información (SGSI)

Conforme a ISO/IEC 27001:2022

PR02 · Blindando la información: gobernanza y cumplimiento

Juan Francisco Ortega Jiménez

Matrícula: 184918

7.° semestre · Ingeniería en Tecnologías de la Información

Sistemas de Gestión de la Seguridad

Mtro. Servando López Contreras

Universidad Politécnica de San Luis Potosí (UPSLP)

San Luis Potosí, 12 de octubre de 2026 · Versión 2.0

Tabla de contenido

01. Alcance.....3
02. Referencias normativas.....4
03. Términos y condiciones.....5
04. Contexto de la organización.....6
05. Liderazgo.....7
06. Planificación.....14
07. Soporte.....16
08. Operación.....18
09. Evaluación del desempeño.....18
10. Mejora.....18

01. Alcance

La empresa

Dirección General: Ing. Araceli Montemayor Reyes — Directora General de Pulso Metropolitano.

Tradición y trayectoria: Pulso Metropolitano nació en 1987 como el organismo operador de agua potable y saneamiento de la zona metropolitana. Durante más de tres décadas construyó su reputación sobre la continuidad del servicio (menos de 6 horas de corte acumulado al año) y, desde 2019, impulsó un programa de modernización digital (facturación en línea, portal ciudadano, telemetría remota de la red de distribución) que hoy constituye la superficie evaluada en este SGSI. La organización se distingue por un fuerte componente de servicio público: su personal técnico de campo convive con equipos de desarrollo de software jóvenes, lo que explica tanto el ritmo de innovación del portal como algunas de las brechas de madurez en seguridad detectadas durante la auditoría.

Datos financieros relevantes: Pulso Metropolitano opera bajo un esquema de organismo público descentralizado, con ingresos provenientes principalmente del cobro de tarifas de agua y saneamiento a cerca de 420,000 cuentas registradas, complementados con transferencias municipales para proyectos de infraestructura. El presupuesto anual estimado de operación (2026) es de $480 millones de pesos, de los cuales el 3.2% ($15.4 millones) corresponde al gasto en Tecnologías de la Información y Comunicaciones, y de ese rubro un 18% ($2.77 millones) se destina a ciberseguridad y continuidad operativa — la partida directamente relacionada con la implementación de este SGSI.

Misión: Garantizar el suministro continuo, seguro y de calidad de agua potable y saneamiento a la zona metropolitana atendida, operando la infraestructura crítica de TI y OT bajo principios de confidencialidad, integridad y disponibilidad de la información.

Visión: Ser un operador de infraestructura crítica de referencia en la gestión integral de la seguridad de la información, con procesos auditables, personal capacitado y tecnología resiliente ante incidentes.

Organigrama funcional

Nivel / rol	Responsabilidad principal
Dirección General	Responsable final del cumplimiento y de la asignación de recursos para el SGSI.
Dirección de Tecnologías de la Información	Administra el portal institucional, los sistemas internos de gestión y la infraestructura de TI.
Dirección de Operaciones (OT)	Supervisa el proceso de potabilización, el SCADA/HMI y los controladores de campo.
Gerencia de Ciberseguridad y Cumplimiento (CISO)	Diseña, implementa y da seguimiento al SGSI; coordina auditorías y respuesta a incidentes.
Gerencia de Atención a Usuarios	Gestiona cuentas, facturación, pagos y el portal de reportes ciudadanos.
Gerencia de Proveedores y Contratos	Administra las relaciones con proveedores de mantenimiento e insumos.
Comité de Seguridad de la Información	Órgano colegiado (Dirección General, CISO, TI, OT, Legal) que aprueba políticas y revisa riesgos.

¿Qué presenta este proyecto? — Vendiendo la ISO/IEC 27001

Este proyecto presenta la implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) conforme a la norma ISO/IEC 27001:2022 para Pulso Metropolitano. ISO/IEC 27001 es el estándar internacional de referencia para la gestión de la seguridad de la información: define los requisitos para establecer, implementar, mantener y mejorar continuamente un marco de controles que proteja la confidencialidad, integridad y disponibilidad de los activos de información de una organización,

independientemente de su tamaño o sector. Para un operador de infraestructura crítica como Pulso Metropolitano, adoptar este estándar significa tres beneficios concretos: (1) reducir el riesgo de incidentes como los 20 identificados en la auditoría técnica mediante controles sistemáticos y verificables, (2) dar a la Dirección General y al Comité de Seguridad un marco auditable y medible de cumplimiento, en vez de medidas aisladas, y (3) sentar las bases para una eventual certificación ISO/IEC 27001, que fortalece la confianza de la ciudadanía y de los entes reguladores en el manejo de un servicio público esencial.

Área seleccionada y delimitación del alcance

Para delimitar el alcance operativo de este SGSI, se seleccionó específicamente la Gerencia de Ciberseguridad y Cumplimiento (CISO), adscrita a la Dirección de Tecnologías de la Información, como la jefatura responsable de liderar la implementación, el mantenimiento y la mejora continua del sistema. Esta gerencia es el punto de coordinación entre la Dirección de TI (portal, bases de datos, APIs) y la Dirección de Operaciones OT (SCADA/HMI, firmware de campo), lo que la convierte en el área natural para gobernar un alcance que —como revela la cadena de ataque IT→OT documentada en el informe de hallazgos— cruza ambos dominios.

Alcance documental: este SGSI cubre los activos de información de cara al usuario (portal, cuentas, pagos, reportes ciudadanos) y los activos internos administrativos y operativos (base de datos, panel administrativo, proveedores, red IT-OT, SCADA/HMI y firmware de campo), descritos en la sección 04.

02. Referencias normativas

Para seleccionar el marco normativo de este SGSI se revisó el universo completo de la familia ISO/IEC 27000 (más de 45 normas y guías publicadas a la fecha, de la ISO/IEC 27000:2018 — Vocabulario — a guías sectoriales específicas como la ISO/IEC 27019 o la ISO/IEC 27799), además de normas y marcos complementarios (NIST, IEC 62443) y la legislación mexicana aplicable. De ese universo se seleccionaron 10 referencias directamente aplicables al contexto de Pulso Metropolitano (tabla siguiente); el resto se descartó por no ser pertinente al sector, al tamaño de la organización o al tipo de activos identificados. La tabla posterior documenta una muestra representativa de normas evaluadas y descartadas, con la justificación de su no aplicación.

Normas seleccionadas como aplicables

Norma / marco	Aplicación en este SGSI
ISO/IEC 27001:2022	Estructura base del SGSI: contexto, liderazgo, planificación, soporte, operación, evaluación y mejora.
ISO/IEC 27002:2022	Catálogo de controles del Anexo A utilizado como referencia para las políticas funcionales.
ISO/IEC 27005:2022	Metodología de gestión de riesgos de seguridad de la información aplicada en la matriz de riesgo.
ISO/IEC 27035-1/2:2023	Gestión de incidentes de seguridad de la información; base conceptual del plan de respuesta.
NIST SP 800-61 Rev. 2	Ciclo de manejo de incidentes (preparación, detección, contención, erradicación, recuperación, lecciones aprendidas).
NIST Cybersecurity Framework (CSF) 2.0	Funciones Identificar, Proteger, Detectar, Responder y Recuperar utilizadas para estructurar los controles por activo.
IEC 62443	Seguridad de sistemas de automatización y control industrial (OT); referencia para los activos de la capa SCADA/HMI y firmware.
Ley Federal de Protección de Datos Personales en Posesión de Particulares (LFPDPPP)	Marco legal mexicano aplicable a los datos personales de usuarios (cuentas, facturación) tratados por INTERAFAS.
Ley General de Protección de Datos Personales en Posesión de Sujetos	Aplicable por tratarse de un operador de un servicio público esencial con

Obligados	componentes gubernamentales/municipales.
Marco de infraestructura crítica (sector hídrico)	Criterios de continuidad operativa y protección de procesos industriales esenciales para la prestación del servicio de agua potable.

Muestra de normas evaluadas y descartadas (no aplicables)

Como evidencia de la revisión del universo completo de la familia ISO/IEC 27000, se documentan a continuación algunas de las normas descartadas y la justificación de su no aplicación:

Norma	Tema	Motivo de no aplicación
ISO/IEC 27017:2015	Controles de seguridad para servicios en la nube (cloud computing).	Pulso Metropolitano opera su infraestructura en servidores propios/on-premise; no contrata actualmente servicios de nube pública en el alcance evaluado.
ISO/IEC 27018:2019	Protección de datos personales (PII) en nubes públicas actuando como procesador.	No aplica por la misma razón que ISO/IEC 27017: no hay un proveedor cloud externo en el alcance que actúe como procesador de datos personales.
ISO/IEC 27799:2016	Gestión de seguridad de la información en el sector salud, basada en ISO/IEC 27002.	Es específica del sector salud (información clínica de pacientes); Pulso Metropolitano no procesa información de este tipo.
ISO/IEC 27019:2017	Controles de seguridad de la información para el sector de la energía.	Aunque es la guía sectorial OT más cercana (fue considerada seriamente por el paralelismo IT-OT), es específica de la industria energética; se prefirió IEC 62443 por ser agnóstica de sector industrial y más general para SCADA/HMI/PLC.
ISO/IEC 27011:2016	Controles de seguridad de la información para organizaciones de telecomunicaciones.	Pulso Metropolitano no es un operador de telecomunicaciones; no aplica.
ISO/IEC 27701:2019	Extensión de ISO/IEC 27001 para gestión de la privacidad (PIMS).	Recomendable a futuro dado el volumen de datos personales de usuarios, pero se consideró fuera del alcance de este primer ciclo del SGSI, que se enfoca en los hallazgos técnicos de la auditoría 2026.

03. Términos y condiciones

Definiciones adoptadas de ISO/IEC 27000:2018 (Vocabulario) para la correcta interpretación de este documento:

Término	Definición
Activo de información	Todo elemento (dato, sistema, servicio o proceso) que tiene valor para la organización y que, por tanto, requiere protección (ISO/IEC 27000:2018, 3.1).
Riesgo de seguridad de la información	Efecto de la incertidumbre sobre los objetivos de seguridad de la información, generalmente expresado en términos de probabilidad e impacto (ISO/IEC 27000:2018, 3.61).
Amenaza	Causa potencial de un incidente no deseado que puede resultar en daño a un sistema u organización (ISO/IEC 27000:2018, 3.74).
Vulnerabilidad	Debilidad de un activo o control que puede ser explotada por una o más amenazas (ISO/IEC 27000:2018, 3.77).
Control	Medida que modifica el riesgo, incluyendo políticas, procedimientos, directrices, prácticas o estructuras organizacionales (ISO/IEC 27000:2018, 3.14).
Confidencialidad	Propiedad de que la información no esté disponible ni sea divulgada a individuos, entidades o procesos no autorizados (ISO/IEC 27000:2018, 3.10).
Integridad	Propiedad de exactitud y completitud de la información y de los activos (ISO/IEC 27000:2018, 3.36).
Disponibilidad	Propiedad de que la información sea accesible y utilizable cuando lo requiera una entidad autorizada (ISO/IEC 27000:2018, 3.7).
Incidente de seguridad de la información	Evento o serie de eventos de seguridad de la información no deseados o

	inesperados que tienen una probabilidad significativa de comprometer las operaciones y amenazar la seguridad de la información (ISO/IEC 27000:2018, 3.31).
Declaración de aplicabilidad (SoA)	Documento que describe los objetivos de control y los controles pertinentes y aplicables al SGSI de la organización (ISO/IEC 27000:2018, 3.21).
Política de seguridad de la información	Intención y dirección de la organización respecto a la seguridad de la información, tal como la expresa formalmente la alta dirección (ISO/IEC 27000:2018, 3.53).
Tecnología operativa (OT)	Hardware y software que detecta o causa un cambio mediante la supervisión y/o control directo de equipos físicos, procesos y eventos industriales (p. ej. SCADA, HMI, PLC, RTU) — término técnico de uso común en la industria, no definido en ISO/IEC 27000 pero referenciado por IEC 62443.
SCADA / HMI	Supervisory Control and Data Acquisition / Human-Machine Interface: sistema y pantalla que permiten a un operador supervisar y controlar remotamente un proceso industrial, en este caso la potabilización y distribución de agua.
PLC / RTU	Controlador Lógico Programable / Unidad Terminal Remota: dispositivos de campo que ejecutan la lógica de control física (válvulas, bombas, sensores) del proceso industrial.
Principio de mínimo privilegio	Práctica de otorgar a cada usuario o sesión únicamente los permisos estrictamente necesarios para realizar su función autorizada, por el tiempo mínimo indispensable.
Segmentación de red IT/OT (modelo Purdue)	Separación lógica y física entre la red corporativa (IT) y la red de tecnología operativa (OT) en niveles jerárquicos, de forma que un compromiso en IT no otorgue acceso directo a los sistemas de control físico.
Verificación de firma criptográfica	Comprobación de que un paquete de software o firmware proviene de una fuente autorizada y no ha sido alterado, mediante criptografía de llave pública — distinta de un simple checksum de integridad, que solo detecta corrupción accidental.

04. Contexto de la organización

Se identificaron 20 activos de información: 10 externos (de cara al usuario/ciudadanía) y 10 internos (administrativos y operativos), cada uno derivado directamente de un hallazgo confirmado en la auditoría técnica.

Activos externos (10)

ID	Activo	Descripción	Hallazgo relacionado
AI-01	**Portal institucional público**	Sitio web público de Pulso Metropolitano; punto de entrada principal para usuarios y ciudadanía.	Reto 1 (archivo público olvidado)
AI-02	**Documentos públicos descargables**	Avisos, manuales y documentos de transparencia publicados en el portal.	Reto 2 (información sensible en recursos del cliente)
AI-03	**Portal de transparencia y cumplimiento**	Sección pública con respaldos e históricos de información regulatoria.	Reto 4 (respaldo/archivo histórico expuesto)
AI-04	**Módulo de exportación de reportes para auditores/terceros**	Función de exportación de reportes consumida por actores externos autorizados.	Reto 5 (divulgación por mensajes de error)
AI-05	**Portal de seguimiento de reportes ciudadanos**	Canal donde los usuarios dan seguimiento a reportes de fallas o incidencias del servicio.	Reto 8 (entrada persistente / XSS almacenado)
AI-06	**Repositorio de documentos descargables de usuario**	Descarga de recibos, contratos y documentos personales de los usuarios.	Reto 9 (path traversal)

AI-07	**Cuentas y perfiles de clientes**	Datos de facturación, consumo y contacto de los usuarios del servicio.	Reto 12 (BOLA)
AI-08	**Flujo de pago en línea de recibos**	Proceso de pago de recibos de agua potable por parte de los usuarios.	Reto 13 (abuso de lógica de negocio en pagos)
AI-09	**API de historial de servicio para usuarios**	Endpoint que expone el historial de servicio de cada cuenta de usuario.	Reto 11 (endpoint no documentado)
AI-10	**Sesión autenticada del usuario**	Mecanismo de sesión que mantiene autenticado a un usuario del portal.	Reto 10 (gestión débil de sesión)

Activos internos (10)

ID	Activo	Descripción	Hallazgo relacionado
AI-11	**Base de datos transaccional**	Repositorio central de datos de clientes, facturación y operación consultado por los sistemas internos.	Reto 7 (inyección SQL ciega)
AI-12	**Panel de gestión administrativa interno**	Panel usado por personal interno para administrar expedientes y operaciones del servicio.	Reto 3 (IDOR)
AI-13	**Módulo de gestión de proveedores y contratos**	Sistema que administra proveedores, contratos de mantenimiento e insumos.	Reto 6 (control de acceso por rol deficiente) / Reto 14 (relación proveedor-contrato)
AI-14	**Documentación de arquitectura y configuración interna**	Documentos y archivos de configuración que describen la arquitectura técnica interna.	Reto 15 (descubrimiento de configuración/arquitectura)
AI-15	**Sistema de autenticación y gestión de sesiones**	Mecanismo de autenticación compartido por los sistemas administrativos internos.	Reto 10 (gestión débil de sesión)
AI-16	**Gateway de interconexión IT-OT**	Punto de interconexión que permite el paso de la red corporativa (IT) a la red operativa (OT).	Reto 16 (bypass de autenticación por cabecera confiada)
AI-17	**Sistema HMI de supervisión de planta (SCADA/HMI simulado)**	Interfaz hombre-máquina que permite supervisar y operar el proceso de potabilización.	Reto 17 (acceso no autorizado a HMI)
AI-18	**Firmware de controladores de campo (PLC/RTU simulado)**	Firmware que opera los controladores de campo del proceso industrial.	Reto 18 (bypass de verificación de firma de firmware)
AI-19	**Sesiones de mantenimiento con privilegio elevado**	Sesiones técnicas usadas por personal de mantenimiento con privilegios elevados sobre OT.	Reto 19 (exceso de privilegio en sesión de mantenimiento)
AI-20	**Parámetros de control crítico del proceso de tratamiento**	Variables operativas críticas (dosificación, presión, niveles) del proceso de potabilización.	Reto 20 (manipulación de parámetro crítico sin validación de rango)

05. Liderazgo

La Dirección General, a través del Comité de Seguridad, declara su compromiso con el SGSI mediante la aprobación de 20 políticas funcionales, una por cada activo de información identificado en la sección 04. Cada política define su estándar de referencia, la directriz general, el procedimiento operativo, la línea base técnica mínima exigible, quién la supervisa y qué ocurre si no se cumple.

Matriz RACI de supervisión y cumplimiento de las políticas funcionales

Como evidencia de liderazgo ante la auditoría, la Dirección General delega la supervisión operativa de cada política en el área correspondiente, manteniendo al Comité de Seguridad como responsable final (Accountable) de su cumplimiento en todos los casos:

Política	R (ejecuta)	A (rinde cuentas)	C (consulta)	I (se informa)
Política de publicación controlada en el portal institucional	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de clasificación de documentos públicos	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de resguardo de respaldos y archivos históricos	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de manejo seguro de errores en módulos de exportación	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de validación de entradas en canales ciudadanos	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de control de acceso a archivos de usuario	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de autorización a nivel de objeto para datos de clientes	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de integridad del flujo de pagos	Gerencia de Atención a Usuarios	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de inventario y exposición de APIs	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de gestión del ciclo de vida de la sesión	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de uso seguro de la base de datos transaccional	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de control de acceso al panel administrativo	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de segregación de roles en gestión de proveedores	Gerencia de Proveedores	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de protección de documentación técnica interna	CISO	Comité de Seguridad de la Información	Dirección de TI	Dirección General
Política de autenticación robusta para sistemas internos	Dirección de TI	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de segmentación y confianza cero entre IT y OT	CISO	Comité de Seguridad de la Información	Dirección de TI	Dirección General
Política de autenticación obligatoria en funciones críticas del HMI	Dirección de Operaciones	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de verificación de integridad de firmware	Dirección de Operaciones	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de mínimo privilegio en sesiones de mantenimiento	Dirección de Operaciones	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General
Política de validación de rango en parámetros críticos del proceso	Dirección de Operaciones	Comité de Seguridad de la Información	CISO / Gerencia de Ciberseguridad	Dirección General

Detalle de las 20 políticas funcionales

01. Política de publicación controlada en el portal institucional (AI-01 · Portal institucional público)

Estándar	A.5.9 / A.8.10
Directriz	Ningún archivo entra al directorio público sin revisión de contenido sensible.
Procedimiento	Checklist de publicación firmado por TI antes de subir cualquier archivo al webroot.
Línea base	Cero archivos de configuración o despliegue accesibles públicamente.
Supervisor	Dirección de TI (ejecución) / CISO (verificación)

Si no se cumple	El hallazgo se reporta al Comité de Seguridad; una reincidencia suspende los permisos de publicación directa del responsable hasta recapacitación.

02. Política de clasificación de documentos públicos (AI-02 · Documentos públicos descargables)

Estándar	A.5.12
Directriz	Todo documento descargable se clasifica antes de publicarse.
Procedimiento	Revisión trimestral del repositorio público contra el catálogo de clasificación.
Línea base	100% de los documentos públicos con etiqueta de clasificación vigente.
Supervisor	Dirección de TI
Si no se cumple	El documento se retira de inmediato del portal; el incumplimiento se documenta en el checklist de evaluación del desempeño (sección 09).

03. Política de resguardo de respaldos y archivos históricos (AI-03 · Portal de transparencia y cumplimiento)

Estándar	A.8.13
Directriz	Los respaldos (.bak y similares) nunca residen en directorios servidos públicamente.
Procedimiento	Barrido automatizado semanal de extensiones de respaldo en rutas públicas.
Línea base	Cero archivos de respaldo accesibles desde Internet.
Supervisor	Dirección de TI (ejecución) / CISO (auditoría)
Si no se cumple	Activación del Plan de Respuesta a Incidentes si el respaldo contenía datos sensibles; reporte formal al Comité de Seguridad.

04. Política de manejo seguro de errores en módulos de exportación (AI-04 · Módulo de exportación de reportes para auditores/terceros)

Estándar	A.8.28
Directriz	Los mensajes de error no revelan rutas, consultas ni información interna.
Procedimiento	Pruebas de manejo de errores incluidas en cada despliegue del módulo de exportación.
Línea base	Mensajes de error genéricos en el 100% de las rutas que procesan datos de usuario.
Supervisor	Dirección de TI
Si no se cumple	El despliegue se revierte hasta corregir el manejo de errores; se documenta como no conformidad menor.

05. Política de validación de entradas en canales ciudadanos (AI-05 · Portal de seguimiento de reportes ciudadanos)

Estándar	A.8.28 / A.8.26
Directriz	Toda entrada capturada en reportes ciudadanos se sanitiza antes de almacenarse o mostrarse.
Procedimiento	Codificación de salida obligatoria (output encoding) en toda vista que renderice contenido enviado por usuarios.

Línea base	Cero hallazgos de XSS almacenado en pruebas de regresión.
Supervisor	Dirección de TI (ejecución) / CISO (pruebas de regresión)
Si no se cumple	Bloqueo del despliegue a producción hasta remediar; si ya estaba en producción, se activa el plan de respuesta a incidentes.

06. Política de control de acceso a archivos de usuario (AI-06 · Repositorio de documentos descargables de usuario)

Estándar	A.8.3
Directriz	La descarga de documentos se resuelve siempre contra un identificador autorizado, nunca contra una ruta de archivo directa.
Procedimiento	Uso obligatorio de un mapeo indirecto (id lógico → ruta física) validado en servidor.
Línea base	Cero accesos fuera del directorio autorizado en pruebas de path traversal.
Supervisor	Dirección de TI
Si no se cumple	Suspensión temporal de la función de descarga hasta corregir el mapeo; reporte al Comité de Seguridad si hubo acceso real no autorizado.

07. Política de autorización a nivel de objeto para datos de clientes (AI-07 · Cuentas y perfiles de clientes)

Estándar	A.8.3 / A.5.15
Directriz	Cada consulta a datos de un cliente valida que el solicitante sea el propietario del recurso o tenga un rol autorizado.
Procedimiento	Middleware de autorización por objeto en todos los endpoints que exponen datos de clientes.
Línea base	Cero casos de BOLA confirmados en pruebas periódicas.
Supervisor	Dirección de TI (ejecución) / CISO (verificación)
Si no se cumple	Notificación obligatoria a los titulares afectados conforme a la LFPDPPP; no conformidad mayor ante el Comité de Seguridad.

08. Política de integridad del flujo de pagos (AI-08 · Flujo de pago en línea de recibos)

Estándar	A.8.26 / A.5.9
Directriz	El monto y los parámetros de un pago se recalculan y validan en servidor, nunca se confían al cliente.
Procedimiento	Validación servidor-autoritativa de monto, cuenta y referencia antes de confirmar cualquier pago.
Línea base	Cero discrepancias entre el monto solicitado por el cliente y el monto cobrado.
Supervisor	Gerencia de Atención a Usuarios (proceso) / Dirección de TI (sistema)
Si no se cumple	Conciliación financiera obligatoria y reporte a Dirección General; el módulo de pago se suspende hasta corregir la validación.

09. Política de inventario y exposición de APIs (AI-09 · API de historial de servicio para usuarios)

Estándar	A.5.9 / A.8.9
Directriz	Ninguna API entra en producción sin estar documentada en el inventario oficial de endpoints.
Procedimiento	Registro obligatorio de API en el inventario antes del despliegue; revisión de autenticación y autorización.
Línea base	100% de los endpoints activos documentados e inventariados.
Supervisor	Dirección de TI
Si no se cumple	El endpoint no inventariado se da de baja hasta su registro formal; se documenta como no conformidad menor.

10. Política de gestión del ciclo de vida de la sesión (AI-10 · Sesión autenticada del usuario)

Estándar	A.8.5
Directriz	Las sesiones expiran por inactividad y se regeneran en cada cambio de privilegio.
Procedimiento	Rotación obligatoria del identificador de sesión tras autenticación exitosa.
Línea base	Cero sesiones reutilizables tras un evento de autenticación.
Supervisor	Dirección de TI
Si no se cumple	Invalidación forzada de todas las sesiones activas del sistema afectado; reporte al CISO.

11. Política de uso seguro de la base de datos transaccional (AI-11 · Base de datos transaccional)

Estándar	A.8.28
Directriz	Toda consulta a la base de datos usa parámetros preparados; ninguna entrada de usuario se concatena directamente.
Procedimiento	Revisión de código obligatoria para cualquier consulta dinámica antes de integrarse a producción.
Línea base	Cero hallazgos de inyección SQL en pruebas de regresión.
Supervisor	Dirección de TI (ejecución) / CISO (revisión de código)
Si no se cumple	Bloqueo del merge/despliegue hasta corregir; no conformidad mayor si llegó a producción.

12. Política de control de acceso al panel administrativo (AI-12 · Panel de gestión administrativa interno)

Estándar	A.8.3 / A.5.15
Directriz	El acceso a expedientes administrativos se valida por identidad y por alcance de rol en cada solicitud.
Procedimiento	Pruebas de autorización horizontal y vertical en cada liberación del panel.
Línea base	Cero accesos cruzados entre expedientes de distintos titulares.
Supervisor	Dirección de TI
Si no se cumple	Suspensión del panel hasta corregir; notificación a los titulares de los

	expedientes expuestos.

13. Política de segregación de roles en gestión de proveedores (AI-13 · Módulo de gestión de proveedores y contratos)

Estándar	A.5.15 / A.8.2
Directriz	Las funciones de alta, modificación y aprobación de proveedores están segregadas por rol.
Procedimiento	Matriz de roles revisada semestralmente contra los privilegios configurados en el sistema.
Línea base	Cero usuarios con permisos de alta y aprobación simultáneos sobre el mismo proveedor.
Supervisor	Gerencia de Proveedores (ejecución) / CISO (revisión semestral)
Si no se cumple	Revocación inmediata de permisos excedentes; auditoría de las operaciones realizadas bajo el conflicto de roles.

14. Política de protección de documentación técnica interna (AI-14 · Documentación de arquitectura y configuración interna)

Estándar	A.5.12 / A.8.10
Directriz	La documentación de arquitectura y configuración se almacena fuera de directorios accesibles desde fuera de la red corporativa.
Procedimiento	Auditoría trimestral de exposición de documentación técnica.
Línea base	Cero documentos de arquitectura accesibles sin autenticación.
Supervisor	CISO / Gerencia de Ciberseguridad
Si no se cumple	Retiro inmediato del documento; evaluación de si la exposición habilitó algún otro hallazgo encadenado.

15. Política de autenticación robusta para sistemas internos (AI-15 · Sistema de autenticación y gestión de sesiones)

Estándar	A.8.5
Directriz	La autenticación interna exige credenciales únicas por usuario y bloqueo tras intentos fallidos.
Procedimiento	Revisión periódica de cuentas compartidas o huérfanas en los sistemas administrativos.
Línea base	Cero cuentas administrativas sin dueño identificado.
Supervisor	Dirección de TI
Si no se cumple	Suspensión de la cuenta huérfana o compartida hasta reasignarla a un titular identificado.

16. Política de segmentación y confianza cero entre IT y OT (AI-16 · Gateway de interconexión IT-OT)

Estándar	A.8.20 / A.8.22
Directriz	Ninguna cabecera, token o encabezado proveniente de la red IT se acepta como prueba de identidad válida en la frontera OT sin verificación independiente.

Procedimiento	Revisión de reglas del gateway IT-OT en cada cambio de configuración, con pruebas de bypass de autenticación.
Línea base	Cero rutas que acepten cabeceras de confianza sin autenticación verificable.
Supervisor	CISO / Gerencia de Ciberseguridad (gobierna la frontera IT-OT)
Si no se cumple	Corte inmediato de la ruta de interconexión hasta corregir; reporte obligatorio a Dirección General por tratarse de la frontera hacia OT.

17. Política de autenticación obligatoria en funciones críticas del HMI (AI-17 · Sistema HMI de supervisión de planta (SCADA/HMI simulado))

Estándar	A.8.5 / IEC 62443-3-3
Directriz	Ninguna función que modifique el estado del proceso se ejecuta sin autenticación y registro de auditoría.
Procedimiento	Pruebas de control de acceso en cada función crítica del HMI antes de su liberación.
Línea base	Cero funciones críticas invocables sin autenticación.
Supervisor	Dirección de Operaciones (OT)
Si no se cumple	Bloqueo de la función crítica hasta corregir; activación del plan de respuesta a incidentes por tratarse de OT.

18. Política de verificación de integridad de firmware (AI-18 · Firmware de controladores de campo (PLC/RTU simulado))

Estándar	A.8.29 / IEC 62443-4-2
Directriz	Ningún firmware se acepta sin validar su firma criptográfica contra una autoridad confiable.
Procedimiento	Verificación de firma obligatoria antes de cualquier actualización de firmware en campo.
Línea base	Cero actualizaciones de firmware aplicadas sin verificación de firma válida.
Supervisor	Dirección de Operaciones (OT) / CISO (gestión de llaves)
Si no se cumple	Reversión inmediata al firmware anterior verificado; notificación a Dirección General por riesgo sobre infraestructura crítica.

19. Política de mínimo privilegio en sesiones de mantenimiento (AI-19 · Sesiones de mantenimiento con privilegio elevado)

Estándar	A.5.15 / A.8.2
Directriz	Las sesiones de mantenimiento otorgan solo los privilegios estrictamente necesarios para la tarea autorizada y por tiempo limitado.
Procedimiento	Elevación de privilegio temporal con aprobación y expiración automática (just-in-time access).
Línea base	Cero sesiones de mantenimiento con privilegio permanente fuera de la ventana autorizada.
Supervisor	Dirección de Operaciones (OT)
Si no se cumple	Revocación inmediata de la sesión; auditoría de todas las acciones realizadas fuera del alcance autorizado.

20. Política de validación de rango en parámetros críticos del proceso (AI-20 · Parámetros de control crítico del proceso de tratamiento)

Estándar	A.8.28 / IEC 62443-3-3
Directriz	Todo parámetro de control crítico se valida contra límites físicos y operacionales seguros antes de aplicarse.
Procedimiento	Doble validación (lógica de aplicación + enclavamiento físico/lógico) para cualquier cambio de parámetro crítico.
Línea base	Cero cambios de parámetro aplicados fuera del rango operacional seguro.
Supervisor	Dirección de Operaciones (OT)
Si no se cumple	Reversión automática al último valor seguro conocido; activación inmediata del plan de respuesta a incidentes por riesgo a la continuidad del servicio.

06. Planificación

La planificación del SGSI parte de la matriz de riesgo 5x5 construida sobre las amenazas identificadas contra cada una de las 20 políticas funcionales de la sección 05. El nivel de riesgo resulta de multiplicar la probabilidad de recurrencia (1 a 5) por el impacto potencial (1 a 5); el puntaje obtenido (1 a 25) se clasifica en cuatro bandas. El tratamiento de cada riesgo no es uniforme: la mayoría de los 20 riesgos identificados se mitigan, pero se documentan además casos reales de transferencia, aceptación y evitación, según lo que resulte más adecuado para cada amenaza.

Escala de calificación

Probabilidad (recurrencia)	Impacto
1 · Muy baja 2 · Baja 3 · Media 4 · Alta 5 · Muy alta	1 · Insignificante 2 · Menor 3 · Moderado 4 · Mayor 5 · Catastrófico

Matriz de riesgo 5x5 (Impacto × Probabilidad)

Cada celda muestra el puntaje (probabilidad × impacto) y, entre paréntesis, cuántos de los 20 riesgos identificados caen en esa combinación:

Impacto 5	5	**10 (3)**	**15 (2)**	**20 (1)**	25
Impacto 4	4	**8 (4)**	**12 (4)**	16	20
Impacto 3	3	6	9	12	15
Impacto 2	2	**4 (1)**	**6 (5)**	8	10
Impacto 1	1	2	3	4	5
	Prob. 1	**Prob. 2**	**Prob. 3**	**Prob. 4**	**Prob. 5**

Leyenda: **Bajo (1-5)** **Medio (6-10)** **Alto (11-15)** **Crítico (16-25)**

Registro de riesgos y tratamiento

ID	Activo	Amenaza	Prob.	Impacto	Nivel	Tratamiento
R-01	AI-01	Publicación accidental de archivos de configuración/despliegue	3	2	Medio	Mitigar
R-02	AI-02	Exposición de información sensible en documentos públicos	3	2	Medio	Mitigar

R-03	AI-03	Exposición de respaldos/históricos en rutas públicas	3	4	**Alto**	Mitigar
R-04	AI-04	Divulgación de información interna vía mensajes de error	3	2	**Medio**	Mitigar
R-05	AI-05	Inyección de contenido malicioso persistente (XSS)	3	4	**Alto**	Mitigar
R-06	AI-06	Acceso no autorizado a archivos fuera del directorio permitido	2	4	**Medio**	Mitigar
R-07	AI-07	Acceso indebido a datos de otros clientes (BOLA)	3	4	**Alto**	Mitigar
R-08	AI-08	Manipulación de parámetros del flujo de pago	2	4	**Medio**	Mitigar
R-09	AI-09	Explotación de endpoints no documentados	3	2	**Medio**	Mitigar
R-10	AI-10	Secuestro o fijación de sesión	2	4	**Medio**	Mitigar
R-11	AI-11	Inyección SQL sobre la base transaccional	4	5	**Crítico**	Mitigar
R-12	AI-12	Acceso cruzado entre expedientes administrativos (IDOR)	3	4	**Alto**	Mitigar
R-13	AI-13	Abuso de privilegios por falta de segregación de roles	3	2	**Medio**	**Transferir**
R-14	AI-14	Reconocimiento de arquitectura interna por exposición de documentación	2	2	**Bajo**	**Aceptar**
R-15	AI-15	Compromiso de cuentas administrativas huérfanas o compartidas	2	4	**Medio**	Mitigar
R-16	AI-16	Bypass de autenticación en la frontera IT-OT por cabeceras confiadas	3	5	**Alto**	**Evitar**
R-17	AI-17	Ejecución de funciones críticas del HMI sin autenticación	2	5	**Medio**	Mitigar
R-18	AI-18	Carga de firmware no íntegro o no autorizado	2	5	**Medio**	Mitigar
R-19	AI-19	Escalamiento mediante sesiones de mantenimiento con privilegio excesivo	2	5	**Medio**	Mitigar
R-20	AI-20	Manipulación de parámetros críticos fuera de rango operacional seguro	3	5	**Alto**	Mitigar

Ejemplos de tratamiento distinto a la mitigación

Tomando una política funcional y la amenaza real que la afecta, se ejemplifican a continuación los cuatro tratamientos de riesgo de ISO/IEC 27005 (mitigar, transferir, aceptar y evitar) con un caso real de cada uno de los tres últimos, documentando el razonamiento del Comité de Seguridad:

R-13 · TRANSFERIR	**Política relacionada: Política de segregación de roles en gestión de proveedores**
Amenaza	Abuso de privilegios por falta de segregación de roles
Prob. × Impacto	3 × 2 = 6 (Nivel Medio)
Justificación del Comité	Se traslada contractualmente a los proveedores la responsabilidad de reportar cualquier uso indebido de sus credenciales de acceso al módulo (cláusula de responsabilidad en el contrato de servicio), complementado con la matriz de roles interna como control secundario.

R-14 · ACEPTAR	**Política relacionada: Política de protección de documentación técnica interna**
Amenaza	Reconocimiento de arquitectura interna por exposición de documentación
Prob. × Impacto	2 × 2 = 4 (Nivel Bajo)
Justificación del Comité	Dado su nivel Bajo (probabilidad baja, impacto menor) y que la documentación expuesta no contenía credenciales ni secretos explotables directamente, el Comité de Seguridad acepta este riesgo con monitoreo trimestral, en vez de invertir en un control adicional cuyo costo excedería el beneficio esperado.

R-16 · EVITAR	**Política relacionada: Política de segmentación y confianza cero entre IT y OT**
Amenaza	Bypass de autenticación en la frontera IT-OT por cabeceras confiadas
Prob. × Impacto	3 × 5 = 15 (Nivel Alto)
Justificación del Comité	En vez de solo mitigar validando mejor la cabecera, se decide evitar la causa raíz del riesgo: eliminar por completo cualquier mecanismo de autenticación basado en cabeceras de red confiadas en la frontera IT-OT y rediseñar el gateway para exigir siempre credenciales criptográficas verificables, dado que el impacto potencial (acceso a la red OT) es catastrófico.

07. Soporte

Minuta de presentación del SGSI a la Dirección

Minuta — Presentación del SGSI a la Dirección — 12 de octubre de 2026 — Sala de juntas de Dirección General, Pulso Metropolitano (INTERAFAS)

Asistentes: Dirección General, Dirección de TI, Dirección de Operaciones (OT), CISO / Gerencia de Ciberseguridad, Gerencia de Atención a Usuarios, Gerencia de Proveedores.

Agenda:

- Presentación del alcance y objetivos del SGSI.
- Revisión de los 20 activos de información identificados y su clasificación interna/externa.
- Presentación de las 20 políticas funcionales y su relación con los hallazgos de la auditoría técnica.
- Revisión de la matriz de riesgo y priorización de tratamientos.
- Presentación de los materiales de prevención (flyer, presentación, curso y video).
- Acuerdos y próximos pasos.

Acuerdos:

- Se aprueba el alcance del SGSI propuesto por la Gerencia de Ciberseguridad.
- Se instruye a Dirección de TI y Dirección de Operaciones implementar las políticas funcionales correspondientes a sus activos en un plazo de 60 días.
- Se autoriza la difusión del material de prevención a todo el personal mediante el curso introductorio y el video de concientización.
- El Comité de Seguridad dará seguimiento trimestral al cumplimiento de la matriz de riesgo mediante los checklists de evaluación del desempeño.

Materiales de apoyo y prevención

Flyer — "No todo lo que brilla es un ahorro: cuida la información de Pulso Metropolitano"

Un archivo olvidado, una sesión abierta o un reporte sin revisar pueden abrir la puerta a un incidente. Reporta cualquier comportamiento inusual al área de Ciberseguridad.

- No comparta credenciales.
- Verifique el remitente antes de abrir archivos adjuntos.
- Reporte archivos o páginas que no reconozca.
- Cierre sesión al terminar su jornada.

Presentación — "Seguridad de la información en Pulso Metropolitano" (8 láminas)

1. ¿Qué es la seguridad de la información y por qué nos importa?
2. Nuestros activos: lo que protegemos todos los días.
3. Amenazas reales: lecciones de la auditoría interna.
4. Nuestras políticas: qué se espera de cada persona.
5. El proceso de agua, en riesgo: por qué la OT también cuenta.
6. Cómo reportar un incidente.
7. Preguntas frecuentes.
8. Contacto del área de Ciberseguridad.

Curso introductorio — "Curso introductorio de seguridad de la información (4 módulos)"

- Módulo 1 — Conceptos básicos: activo, amenaza, vulnerabilidad, riesgo.
- Módulo 2 — Políticas de Pulso Metropolitano: qué debo hacer y qué no.
- Módulo 3 — Seguridad en sistemas administrativos y de atención a usuarios.
- Módulo 4 — Seguridad en la operación (OT): por qué un proceso físico también se protege.

Video de concientización — "Video de concientización — "Una gota puede ser una fuga" (3 minutos)"

1. Escena 1 — Un empleado encuentra un archivo que no debería estar público.
2. Escena 2 — Se explica qué pasó y por qué importa (sin tecnicismos).
3. Escena 3 — Se muestra el proceso correcto de reporte.
4. Escena 4 — Testimonio del CISO sobre la importancia de cada rol.
5. Escena 5 — Cierre con los datos de contacto del área de Ciberseguridad.

08. Operación

La operación del SGSI se sostiene en la matriz RACI siguiente, que define quién ejecuta (R), quién rinde cuentas (A), a quién se consulta (C) y a quién se informa (I) en cada actividad clave.

Actividad	R	A	C	I
Aprobación de políticas del SGSI	CISO / Gerencia de Ciberseguridad	Comité de Seguridad	Dirección de TI, Dirección de Operaciones	Gerencia de Atención a Usuarios, Gerencia de Proveedores
Gestión de la base de datos y aplicaciones web (IT)	Dirección de TI	CISO / Gerencia de Ciberseguridad	Gerencia de Proveedores	Comité de Seguridad
Gestión del SCADA/HMI y firmware (OT)	Dirección de Operaciones (OT)	CISO / Gerencia de Ciberseguridad	Dirección de TI	Comité de Seguridad
Atención de cuentas, pagos y reportes ciudadanos	Gerencia de Atención a Usuarios	Dirección de TI	CISO / Gerencia de Ciberseguridad	Comité de Seguridad
Gestión de proveedores y contratos	Gerencia de Proveedores	Dirección General	CISO / Gerencia de Ciberseguridad	Dirección de TI
Evaluación de riesgos y matriz de riesgo	CISO / Gerencia de Ciberseguridad	Comité de Seguridad	Dirección de TI, Dirección de Operaciones	Dirección General
Respuesta a incidentes de seguridad	CISO / Gerencia de Ciberseguridad	Dirección General	Dirección de TI, Dirección de Operaciones	Gerencia de Atención a Usuarios
Capacitación y materiales de prevención	CISO / Gerencia de Ciberseguridad	Dirección de TI	Gerencia de Atención a Usuarios	Comité de Seguridad
Auditoría interna y checklists de desempeño	Comité de Seguridad	Dirección General	CISO / Gerencia de Ciberseguridad	Dirección de TI, Dirección de Operaciones

09. Evaluación del desempeño

El desempeño del SGSI se evalúa trimestralmente mediante el siguiente checklist, aplicado por el Comité de Seguridad:

Reactivo	Criterio de verificación
¿Las 20 políticas funcionales cuentan con responsable asignado?	Sí/No por política
¿Se realizó al menos una revisión de riesgo por activo en el periodo?	Sí/No por activo
¿El personal completó el curso introductorio de seguridad?	% de personal capacitado
¿Se registraron incidentes de seguridad en el periodo y se documentaron conforme al plan de respuesta?	Sí/No + número de incidentes
¿La matriz RACI sigue vigente respecto a la estructura organizacional actual?	Sí/No
¿Se revisaron los materiales de prevención en el periodo?	Sí/No
¿Existen hallazgos de la auditoría técnica sin política o control asociado?	Número de hallazgos sin cobertura

10. Mejora

Los resultados del checklist de evaluación del desempeño (sección 09) alimentan el siguiente checklist de mejora continua, que determina qué políticas, controles o materiales deben rediseñarse:

Condición detectada	Acción de mejora
Políticas con bajo cumplimiento detectado en la evaluación del desempeño	Rediseñar la política: simplificar el procedimiento o reforzar la directriz.
Activos con riesgo residual Alto o Crítico tras la aplicación de controles	Priorizar inversión y revisión de la línea base técnica del activo.
Materiales de prevención con baja comprensión o baja participación	Rediseñar el material (flyer, presentación, curso o video) con lenguaje más claro o un canal distinto.
Roles RACI que generan cuellos de botella o ambigüedad en incidentes reales	Reasignar responsabilidades y actualizar la matriz RACI.

Nuevos activos o procesos no cubiertos por el alcance actual	Incorporar el activo al inventario y generar su política funcional correspondiente.

La mejora continua cierra el ciclo PHVA del SGSI: lo detectado en la operación y evaluación regresa a la planificación (sección 06) y, de ser necesario, redefine la política funcional correspondiente (sección 05).